

INFORME DE RESPUESTA A INCIDENTES

Detección y Análisis de Ataque de Fuerza Bruta SSH

Autor: Nicolás Sotomayor

Rol: SOC Analyst (Junior)

Fecha: Mayo 2026

Índice

1. Resumen Ejecutivo	3
2. Alcance	3
3. Descripción del Entorno	3
4. Descripción del Incidente	3
5. Evidencia y Análisis de Logs	4
6. Indicadores de Compromiso (IoC)	4
7. Análisis Técnico	5
8. Clasificación según MITRE ATT&CK	5
9. Evaluación del Impacto	5
10. Medidas de Contención y Mitigación	5
11. Línea de Tiempo del Incidente	6
12. Conclusión	6
13. Recomendaciones Finales	6
14. Detección mediante SIEM	6

1. Resumen Ejecutivo

El día 15 de mayo de 2026 se detectó actividad anómala en el servicio SSH del host **192.168.93.130**, caracterizada por múltiples intentos fallidos de autenticación provenientes de una única dirección IP (**192.168.93.128**).

El análisis de los registros del sistema evidenció un patrón consistente con un ataque automatizado de fuerza bruta dirigido al usuario vagrant. Durante el incidente, el servicio SSH aplicó mecanismos de protección, finalizando conexiones tras superar el número máximo de intentos permitidos.

No se identificaron eventos de autenticación exitosa, por lo que no se confirma compromiso del sistema durante el período analizado.

2. Alcance

La presente investigación tuvo como objetivo:

- Analizar los registros de autenticación del servicio SSH
 - Identificar el origen de los intentos de acceso
 - Evaluar patrones de comportamiento asociados al incidente
 - Determinar la existencia de un posible compromiso de credenciales
-

3. Descripción del Entorno

Host atacante: Kali Linux (192.168.93.128)

Host objetivo: Ubuntu Server (192.168.93.130)

Servicio afectado: SSH (Puerto 22)

Sistema operativo: Ubuntu 14.04 LTS

4. Descripción del Incidente

Se identificó un ataque de fuerza bruta dirigido al servicio SSH del sistema objetivo. El atacante realizó múltiples intentos de autenticación utilizando distintas combinaciones de contraseñas contra el usuario vagrant.

El comportamiento observado presenta características típicas de herramientas automatizadas, evidenciado por la alta frecuencia de intentos y la repetición sistemática de accesos fallidos en intervalos cortos de tiempo.

El sistema objetivo respondió mediante mecanismos de protección integrados en el servicio SSH, bloqueando temporalmente las conexiones tras superar el umbral máximo de intentos de autenticación permitidos.

5. Evidencia y Análisis de Logs

El análisis del archivo `/var/log/auth.log` permitió identificar eventos relevantes asociados al incidente.

Se detectaron múltiples registros de fallos de autenticación:

Failed password for vagrant from 192.168.93.128 port XXXX ssh2

Asimismo, se observaron eventos que indican la activación de controles de seguridad del sistema:

error: maximum authentication attempts exceeded

Disconnected: Too many authentication failures

Estos registros permiten concluir que:

- Se produjo un volumen elevado de intentos de autenticación en un corto período de tiempo
 - Todos los intentos se originaron desde una única dirección IP
 - El comportamiento corresponde a un ataque automatizado
 - El servicio SSH aplicó controles de protección para mitigar el impacto
-

6. Indicadores de Compromiso (IoC)

Dirección IP origen: 192.168.93.128

Servicio objetivo: SSH (Puerto 22)

Usuario objetivo: vagrant

Eventos detectados:

- Failed password
 - Maximum authentication attempts exceeded
 - Disconnected: Too many authentication failures
-

7. Análisis Técnico

El patrón de eventos identificado en los registros del sistema es consistente con un ataque de fuerza bruta orientado a la obtención de credenciales válidas.

Las características principales del ataque incluyen:

- Alta frecuencia de intentos de autenticación
- Persistencia sobre un mismo usuario objetivo
- Uso de una única dirección IP de origen
- Repetición sistemática de intentos en intervalos reducidos

Este comportamiento es indicativo del uso de herramientas automatizadas de ataque, tales como Hydra, utilizadas comúnmente para ataques de diccionario o fuerza bruta.

8. Clasificación según MITRE ATT&CK

Táctica: Credential Access

Técnica: T1110 – Brute Force

Subtécnica: T1110.001 – Password Guessing

9. Evaluación del Impacto

Nivel de severidad: Medio

Justificación:

- Intento de compromiso de credenciales
 - Riesgo potencial de acceso no autorizado
 - No se evidencia actividad post-explotación
 - Existe riesgo potencial en entornos productivos si no se aplican controles adecuados
-

10. Medidas de Contención y Mitigación

Se recomiendan las siguientes acciones:

1. Bloquear la dirección IP atacante mediante firewall
2. Implementar herramientas de protección como Fail2Ban
3. Deshabilitar la autenticación por contraseña en SSH
4. Configurar autenticación mediante claves públicas
5. Limitar la cantidad de intentos de autenticación

6. Monitorear continuamente los registros de acceso
 7. Integrar los logs en un sistema SIEM para detección temprana
-

11. Línea de Tiempo del Incidente

- Inicio de múltiples intentos fallidos de autenticación SSH
 - Incremento sostenido en la frecuencia de intentos
 - Activación del límite máximo de autenticación del servicio SSH
 - Desconexión automática del origen atacante.
-

12. Conclusión

El incidente analizado corresponde a un ataque de fuerza bruta dirigido al servicio SSH, detectado mediante el análisis de logs del sistema.

La identificación temprana del patrón de ataque y la existencia de mecanismos de protección en el servicio permitieron limitar el impacto del incidente.

No se evidenció acceso exitoso ni compromiso del sistema durante el período evaluado.

Este caso resalta la importancia de implementar controles de seguridad adecuados, así como de mantener un monitoreo constante de eventos de autenticación para detectar comportamientos anómalos.

13. Recomendaciones Finales

- Fortalecer políticas de autenticación
 - Implementar soluciones SIEM (Wazuh, Splunk, etc.)
 - Realizar auditorías periódicas de accesos
 - Capacitar al personal en detección y respuesta ante incidentes
-

14. Detección mediante SIEM

La actividad observada durante el incidente puede ser detectada mediante la correlación de eventos en un sistema SIEM, a partir del análisis de logs de autenticación del sistema Linux.

El patrón identificado corresponde a múltiples intentos fallidos de autenticación en un intervalo de tiempo reducido desde una misma dirección IP, lo cual es característico de un ataque de fuerza bruta contra el servicio SSH.

Tipo de detección

Detección basada en comportamiento (Behavior-based detection)
Correlación de eventos (Event Correlation)

Fuente de datos

Archivo de logs: /var/log/auth.log
Servicio monitoreado: SSH (puerto 22)
Eventos relevantes: Failed password

Lógica de detección

La detección del incidente se basa en la siguiente condición:

- Más de 5 intentos fallidos de autenticación
- Desde una misma dirección IP
- En un período menor a 60 segundos

Cuando se cumple esta condición, el sistema genera una alerta por posible ataque de fuerza bruta.

Ejemplo de implementación conceptual en SIEM

Splunk

```
index=linux sourcetype=auth.log "Failed password"  
| bucket _time span=1m  
| stats count by _time, src_ip, user  
| where count > 5
```

Wazuh

```
<rule id="100001" level="10">  
  <if_sid>5710</if_sid>  
  <description>Posible ataque de fuerza bruta SSH detectado</description>  
  <group>authentication_failed, ssh, brute_force</group>
```

```
<frequency>5</frequency>  
<timeframe>60</timeframe>  
</rule>
```

Interpretación de la alerta

La correlación de múltiples eventos de autenticación fallida en un corto período de tiempo permite identificar de forma temprana intentos de acceso no autorizado.

Este tipo de detección resulta fundamental en entornos SOC, ya que posibilita:

- Identificar ataques automatizados de manera oportuna
 - Priorizar incidentes en función de su criticidad
 - Activar mecanismos de respuesta temprana
 - Reducir el riesgo de compromiso de credenciales
-

Valor operativo

La implementación de reglas de correlación en un SIEM permite transformar eventos aislados en alertas significativas, facilitando la detección de comportamientos anómalos que, de otro modo, podrían pasar desapercibidos.

En este caso, la detección basada en comportamiento permite identificar patrones de ataque sin depender de firmas específicas, mejorando la capacidad de respuesta ante amenazas reales.